0930 课后任务

整理身份认证以及知识库问答的实现方案

一、任务理解与方案范围

本方案结合 CampusClaw 当前前后端代码，梳理两条实现链路：一是基于 JWT 的用户身份认证与课程级授权；二是基于课程资料知识库的检索增强问答（RAG）。文档区分“代码中已经实现的机制”和“需要外部服务配置或进一步验证的部分”。

- 认证目标：邮箱验证码注册、密码登录、刷新令牌、退出和密码重置。
- 授权目标：所有业务 API 以登录身份为入口，再按课程 Membership 判断教师或学生权限。
- 知识库目标：课程资料抽取文本、切片、生成向量，在课程范围内检索，并把检索片段作为回答依据返回引用。
- 当前边界：默认模型提供方为 mock；真实大模型和嵌入服务是否可用，取决于环境变量和服务端配置。

二、整体架构

层次	主要实现	职责
前端	Vue 3 + TypeScript；frontend/src/auth.ts、api.ts	保存登录状态、自动刷新 access token、为业务请求添加 Bearer 头；展示课程 Agent 对话和引用。
后端 API	Django + Django REST Framework	用户、课程、资料、作业、Agent 线程及权限校验；签发和校验 JWT。
认证组件	djangorestframework-simplejwt + token_blacklist	生成 access/refresh，轮换 refresh，注销时加入黑名单。
数据层	PostgreSQL（生产）；SQLite（未设置 POSTGRES_HOST 时的本地回退）	保存用户、成员关系、资料、知识条目、切片、向量、对话和运行事件。
模型服务	MODEL_* 与 EMBEDDING_* 环境变量	负责流式回答和文本嵌入；未配置时可使用 mock 验证流程，但不能代表真实模型效果。

三、基于 Token 的身份认证方案

3.1 Token 组成与生命周期

Token	保存位置/用途	当前配置
Access token	前端仅保存在内存；请求时放入 Authorization: Bearer <token>	有效期 5 分钟；用于访问业务 API。
Refresh token	当前标签页 sessionStorage；只用于换取新的 token 对	有效期 7 天；刷新时轮换；旧 refresh 会被加入黑名单。
密码	Django 密码哈希；不以明文保存	密码重置后旧 access token 会因密码哈希校验失效。

后端在 settings.py 中配置 JWTAuthentication、Bearer 头、短期 access token、长期 refresh token、轮换与黑名单。前端在收到 401 时尝试刷新 access token，再重试原请求；退出时提交 refresh token，后端验证其 user_id 属于当前用户后执行 blacklist。

3.2 注册、登录、退出流程

1. 发送验证码：POST /api/auth/code/，purpose=register 或 reset。验证码随机生成，数据库只保存哈希；验证码有效期 10 分钟，60 秒内不能重复发送，最多尝试 5 次。
2. 邮箱注册：POST /api/auth/register/。服务端校验验证码、邮箱唯一性和 Django 密码策略，创建用户后直接返回 access/refresh。
3. 密码登录：POST /api/auth/login/。使用 Django authenticate 校验邮箱和密码，成功后签发新的 token 对。
4. 刷新：POST /api/auth/refresh/。SimpleJWT 校验 refresh 并轮换令牌；已黑名单的旧 refresh 不能再次使用。
5. 退出：POST /api/auth/logout/。校验 refresh 所属用户后拉黑；前端清理 sessionStorage 和内存 token。
6. 找回密码：POST /api/auth/code/（purpose=reset）后调用 POST /api/auth/reset/；重设密码并使旧 access token 失效。

3.3 课程级授权边界

用户身份与课程角色分离：User 表代表账号，Membership 表代表用户在某一门 Course 中的角色。因而同一账号可以在课程 A 是教师，在课程 B 是学生。业务视图通过 member(user, course_id, role) 或课程成员检查函数进行授权。

场景	权限判断
查看课程资料、知识库搜索	必须是该课程 Membership 成员。

创建课程	用户需要兑换一次性、可过期的教师邀请码，获得 can_create_course 资格；创建后自动成为教师。
加入课程	凭课程码加入，角色固定为 student；重复成员关系由唯一约束和业务检查阻止。
上传/发布/重建索引	仅该课程教师。
Agent 线程和附件	线程属于创建者；课程线程还必须满足课程成员关系，附件必须属于当前用户及对应课程。
退出登录	不能注销其他用户的 refresh token。

3.4 关键 API

接口	方法	作用
/api/auth/code/	POST	发送注册或重置验证码。
/api/auth/register/	POST	验证码注册并返回 token 对。
/api/auth/login/	POST	密码登录并返回 token 对。
/api/auth/refresh/	POST	轮换 refresh，返回新 token 对。
/api/auth/logout/	POST	拉黑当前用户的 refresh。
/api/auth/reset/	POST	验证码重置密码。
/api/me/	GET	获取当前账号信息。
/api/teacher-invite/redeem/	POST	兑换教师邀请码。

四、基于知识库问答的实现方案

4.1 数据模型

模型	核心字段/关系	用途
Material	course、attachment、title	课程资料业务对象。
KnowledgeEntry	material 一对一、body_text、parser、status、content_hash	记录资料解析结果和索引状态。
KnowledgeChunk	entry、chunk_index、chunk_text、start_offset/end_offset	保存文本切片及其原文位置。
ChunkEmbedding	chunk 一对一、embedding、model、dimensions	保存 2048 维向量及嵌入模型信息。
AgentThread/Message/Run/Event	owner、course、role、content、citations、运行事件	保存对话、回答引用、流式运行状态和工具调用。

4.2 入库与索引流程

7. 教师上传资料后，资料保存为统一附件记录；可调用资料或课程重建索引接口。

8. extract_text 按扩展名解析 TXT、Markdown、CSV、PDF、DOCX；图片可进入附件理解流程，但当前文本索引不从图片中提取正文。
9. 文本按 auto 策略切片，默认最大约 800 字符、重叠约 80 字符，并记录每个切片的起止偏移。
10. 调用 EMBEDDING_BASE_URL/EMBEDDING_API_KEY/EMBEDDING_MODEL 对切片生成向量；默认要求 2048 维。
11. 成功后写入 KnowledgeEntry、KnowledgeChunk 和 ChunkEmbedding，并标记 ready；失败时记录 failed 和 error_message，便于界面提示和重试。

4.3 检索流程

knowledge_search 接口先检查当前用户是否属于课程，再按 mode 执行检索：keyword 使用 PostgreSQL 文本相似度；vector 使用余弦距离；hybrid 并行执行两者并通过 Reciprocal Rank Fusion（RRF）合并排序。所有查询都带 course_id 范围，因此不会把其他课程的资料混入结果。

每条命中结果包含资料标题、文件名、切片编号、原文偏移、摘要片段、下载地址和预览地址，可作为前端引用卡片的数据来源。

4.4 问答与引用流程

12. 前端创建课程 Agent 线程，并通过 POST /api/agent/threads/{id}/messages/stream/ 发送消息。
13. 只有请求 use_course_materials=true 且线程属于课程时才检索课程资料；普通对话不会自动查询知识库。
14. 无命中时直接返回“资料中未找到相关内容”，不调用模型，避免模型凭空编造课程答案。
15. 有命中时，服务端把检索片段加入 system prompt，并通过 SSE 先发送 citation 事件，再流式发送模型回答。提示词要求使用 [1]、[2] 标注引用。
16. 回答、引用、运行事件和可能生成的 PDF/DOCX 产物会持久化，课程成员和线程所有者边界由后端再次校验。

4.5 关键 API

接口	方法	作用
/api/courses/{id}/knowledge/search/	GET	课程范围内进行关键词、向量或混合检索。
/api/courses/{id}/knowledge/reindex/	POST	教师重建课程全部资料索引。
/api/materials/{id}/reindex/	POST	教师重建单份资料索引。
/api/materials/{id}/preview/	GET	成员查看已抽取的文本预览。
/api/agent/threads/	GET/POST	列出或创建 Agent 线程。
/api/agent/threads/{id}/messages/stream/	POST	发送消息并以 SSE 流式返回回答、引用和工具事件。
/api/agent/tools/{name}/execute/	POST	在后端注册工具范围内执行课程

		读取或产物生成。

五、安全、异常与验证要点

- 验证码：哈希存储、有效期、发送间隔、尝试次数和一次性消费，需测试过期、错误次数耗尽和重复使用。
- Token：需测试 access 过期后的自动刷新、refresh 轮换、旧 refresh 黑名单和跨用户注销。
- 课程权限：需测试跨课程搜索、资料预览、线程、附件和产物访问均被拒绝。
- 知识库：未配置嵌入服务时，索引应进入 failed 并返回明确原因；无命中不调用模型。
- 模型配置：README 约定 MODEL_PROVIDER=mock 可验证流式流程；真实模型需要 MODEL_API_BASE、MODEL_API_KEY、MODEL_NAME，真实向量检索需要 EMBEDDING_* 配置。
- 当前文档是实现方案整理，不宣称真实 SMTP、真实大模型或 Docker 已在本次生成文档时完成端到端验收。

六、结论与后续改进

当前代码已经形成“认证 → 课程成员授权 → 资料索引 → 课程范围检索 → 带引用流式回答”的闭环。后续应优先补充真实服务配置下的端到端测试、异步索引任务和更细粒度的审计日志；再考虑论坛、文件预览、在线测验、题库和知识图谱。AI 学情诊断需要单独确定参考答案来源、图片识别、人工复核、数据保留期限和学生可见范围，再决定报告格式与模型接入方式。

附：代码依据

主要依据文件：backend/campus/settings.py、backend/core/views.py、backend/core/agent_runtime.py、backend/core/agent_views.py、backend/core/models.py、backend/core/urls.py、frontend/src/auth.ts、frontend/src/api.ts、README.md。